TOPIC 6: DATA SECURITY AND MALWARE DEFENSE

Official Undergraduate Lecture Slide Deck (Academic Year 2026/2027)

- Curriculum Coverage: Physical Protection (6.1) | Unauthorized Access & Crypto (6.2) | Malware Defense (6.3)
- **Course Instructor: Madam Bertha Msuliche Lebalwa (MSc)**
- Assessment Structure: 2 Assignments (5%), 2 Tests (15%), Practical Report (10%), Practical Test (30%), UE (40%)*

**Assessment weightings are subject to adjustment by the course instructor.*

Topic 6: Lecture Outline & Learning Roadmap

Data Security, Malware Defense & Cryptography (Coverage: 6.1, 6.2, 6.3)

• Section 6.1: Physical & Environmental Data Protection

- Datacenter environmental threats: Power disturbances (sags, spikes, surges, blackouts)
- Uninterruptible Power Supplies (UPS): Standby, Line-Interactive, Online Double-Conversion topologies
- Environmental controls: HVAC cooling, ASHRAE standards, and clean agent fire suppression (FM-200)
- Backup engineering: Full, Differential, Incremental strategies; The 3-2-1 backup rule; RTO vs RPO

• Section 6.2: Controlling Unauthorized Logical Access & Applied Cryptography

- Identification, Authentication, Authorization, Accounting (IAAA); Kerckhoffs's Principle
- Symmetric cryptography: AES, block cipher operational modes (ECB vs CBC vs GCM)
- Asymmetric cryptography: RSA, Elliptic Curve (ECC), Public/Private key pairs, Digital Signatures
- Cryptographic hash functions (SHA-256) and Public Key Infrastructure (PKI / X.509)

• Section 6.3: Malware Classifications, Attack Vectors & Anti-Malware Defense

- Malware taxonomy: Viruses, Worms, Trojans, Ransomware, Spyware, Rootkits, Botnets
- Defensive technologies: Signatures, Heuristics, Behavioral monitoring, Sandboxing, EDR
- Incident response lifecycle: NIST SP 800-61 framework (Containment, Eradication, Recovery)

CAPSTONE TOPIC

Protecting digital agricultural assets, research findings, and institutional infrastructure against physical failure, logical intrusion, and malicious software attacks.

Topic 6: Intended Learning Outcomes (ILOs)

Core Information Assurance Competencies

- Formulate comprehensive physical and environmental security controls for institutional datacenters.
- Calculate UPS power sizing requirements (Watts vs VA) and evaluate UPS circuit topologies.
- Design enterprise backup schedules meeting strict Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).
- Contrast Symmetric (AES) and Asymmetric (RSA/ECC) encryption in key management and throughput.
- Explain the cryptographic mechanism of digital signatures in guaranteeing authenticity and non-repudiation.
- Classify malware specimens according to infection vectors, replication mechanisms, and payload capabilities.
- Execute the NIST SP 800-61 Computer Security Incident Response lifecycle against live threat outbreaks.

The CIA Triad: Foundations of Data Security

Confidentiality, Integrity, Availability within Academic Computing

- 1. Confidentiality: Assurance that information is not disclosed to unauthorized individuals, entities, or processes.
  - Threats: Eavesdropping, packet sniffing, credential theft, unauthorized database dumps.
  - Mitigations: Whole Disk Encryption (BitLocker), TLS network encryption, Least Privilege access.
- 2. Integrity: Guarding against improper information modification or destruction; ensuring non-repudiation and authenticity.
  - Threats: Unauthorized data tampering, man-in-the-middle alterations, silent bit-rot.
  - Mitigations: SHA-256 cryptographic hashes, digital signatures, database transaction ACID logs.
- 3. Availability: Ensuring timely, reliable access to data and computational services for authorized users.
  - Threats: Distributed Denial of Service (DDoS), ransomware encryption, power grid failure, hardware faults.
  - Mitigations: Redundant UPS power, RAID arrays, automated offsite backups, disaster recovery clusters.

Environmental Security: Power Disturbances

Protecting Microcomputers from Electrical Grid Anomalies

• Power Disturbance Taxonomy:

- Blackout: Complete loss of electrical power for seconds to days; causes sudden system halting and uncommitted cache data loss.
- Brownout (Sag): Prolonged drop in voltage below nominal levels (e.g., drops to 170V on 230V mains); forces power supplies to draw excessive current, overheating capacitors.
- Spike / Surge: Transient high-voltage pulse (microseconds to milliseconds) reaching thousands of volts (lightning, industrial switching); destroys silicon semiconductor gates.
- Electrical Noise (EMI/RFI): High-frequency fluctuations disrupting digital signals on motherboard traces.

• Mitigations: Surge protectors (Metal Oxide Varistors - MOVs), Automatic Voltage Regulators (AVRs), clean dedicated earth grounding, and Uninterruptible Power Supplies (UPS).

Uninterruptible Power Supply (UPS) Topologies

Evaluating Standby vs Line-Interactive vs Online Double-Conversion

- 1. Standby (Offline) UPS:
  - Inverter remains idle; utility power passes directly to load; battery engages via transfer switch during outage.
  - Transfer Time: 4 to 12 ms; acceptable for consumer PCs, unacceptable for sensitive enterprise servers.
- 2. Line-Interactive UPS:
  - Includes multi-tap autotransformer (AVR) that boosts low voltages and bucks high voltages without depleting battery.
  - Transfer Time: 2 to 4 ms; standard choice for office workstations and network closets.
- 3. Online Double-Conversion UPS (Enterprise Gold Standard):
  - Incoming AC power continuously rectified to DC, which continuously charges battery and feeds inverter generating pristine new AC.
  - Transfer Time: EXACTLY 0 ms (Zero transfer time); provides absolute electrical isolation from grid disturbances.

Quantitative UPS Power Sizing Calculations

Real Power (Watts) versus Apparent Power (Volt-Amperes)

- Real Power (P, Watts): Actual electrical power consumed by hardware performing work: $P = V \cdot I \cdot \cos(\theta)$.
- Apparent Power (S, Volt-Amperes): Total power flowing through the circuit: $S = V \cdot I$.
- Power Factor (PF): Ratio of Real Power to Apparent Power: $PF = P / S = \cos(\theta)$ (typically 0.8 to 0.95 for modern IT).
- Sizing Equation: Required UPS Rating (VA) = Total Connected Watts / Power Factor.
- Worked Sizing Example for SUA DIIT Lab:
  - Connected Load: 20 Microcomputers @ 250 W each = 5,000 W.
  - Power Factor of switched-mode power supplies = 0.85.
  - Apparent Power = 5,000 W / 0.85 = 5,882 VA ≈ 5.88 kVA.
  - Applying 25% safety expansion headroom = 5.88 kVA × 1.25 = 7.35 kVA.
  - Specification Recommendation: Procure an 8 kVA or 10 kVA Online Double-Conversion UPS.

The 3-2-1 Enterprise Backup Rule

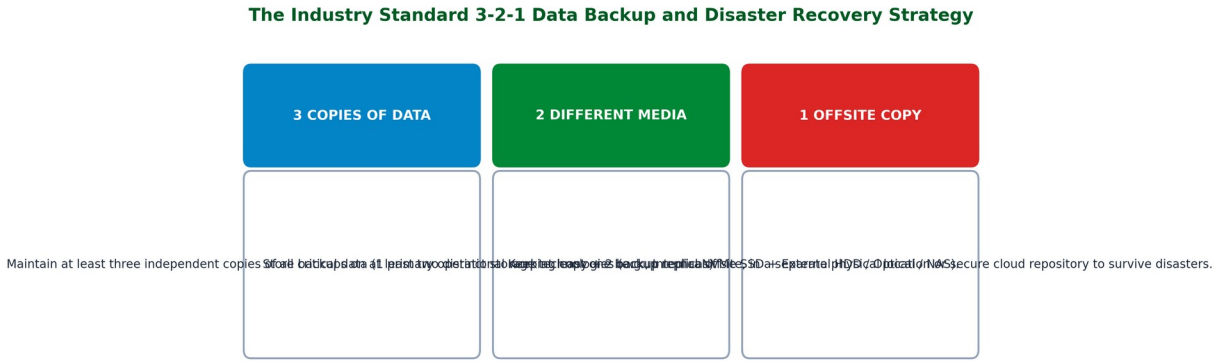


Figure: The gold standard for disaster recovery: 3 copies, 2 different media, 1 offsite/air-gapped copy.

ARCHITECTURAL ANALYSIS & PRINCIPLES

- 3 Copies of Data: Maintain the original production data plus at least 2 distinct backup copies.
- 2 Different Storage Media: Utilize diverse media types (e.g., NVMe NAS server + magnetic LTO tape or optical disc) to eliminate media-specific systemic failures.
- 1 Offsite or Air-Gapped Copy: Store at least one copy in a geographically separate facility or cloud vault completely disconnected from the network to survive fire, floods, and ransomware outbreaks.
- Immutability: Write-Once-Read-Many (WORM) storage locks preventing ransomware from deleting backups.

Backup Strategies: Full, Differential & Incremental

Balancing Backup Window Duration with Restoration Complexity

• Full Backup: Copies every single file across the entire selected volume; resets the Archive (`A`) attribute bit.

- Pros: Fastest and simplest restore (requires only 1 backup set).
- Cons: Takes the longest time to run; consumes massive storage capacity.

• Differential Backup: Copies only files that have been created or modified since the LAST FULL backup; does NOT reset the Archive bit.

- Pros: Fast restore (requires Full Backup + Latest Single Differential Backup).
- Cons: Daily backup size grows progressively larger as week advances.

• Incremental Backup: Copies only files created or modified since the LAST BACKUP OF ANY KIND (Full or Incremental); resets the Archive bit.

- Pros: Fastest backup execution; minimal daily storage consumption.
- Cons: Slowest, most complex restore (requires Full Backup + ALL sequential intermediate incrementals).

Disaster Recovery Metrics: RTO and RPO

Defining Quantitative Tolerances for Downtime and Data Loss

- Recovery Point Objective (RPO):
  - The maximum acceptable age of files that must be recovered from backup storage for normal operations to resume.
  - Measures acceptable data loss in time (e.g., an RPO of 4 hours means the organization can tolerate losing at most 4 hours of transactional work).
  - Dictates the frequency of backup snapshots.
- Recovery Time Objective (RTO):
  - The maximum acceptable duration of time that a system can remain offline following a disaster before normal service is restored.
  - Measures acceptable downtime (e.g., an RTO of 2 hours means systems must be fully re-imaged, data restored, and online within 120 minutes).
  - Dictates disaster recovery infrastructure (hot standby sites vs cold tape restores).

Cryptographic Foundations & Kerckhoffs's Principle

The Mathematical Shield Protecting Digital Communications

- Kerckhoffs's Principle (Auguste Kerckhoffs, 1883):
  - 'A cryptosystem should be secure even if everything about the system, except the key, is public knowledge.'
  - Elimination of 'Security through Obscurity': Robust algorithms (AES, RSA) rely on public mathematical rigor, not secret proprietary code.
- Fundamental Concepts:
  - Plaintext (P): Original unencrypted human-readable or binary data.
  - Ciphertext (C): Encrypted scrambled data output by cipher: C = E_K(P).
  - Key (K): Secret mathematical parameter controlling encryption and decryption transformations.
  - Decryption: Inversion operation returning plaintext: P = D_K(C).

Symmetric Cryptography: AES and Operational Modes

Shared Secret Keys, High Throughput, and Block Cipher Modes

• Symmetric Cipher Principle: A single secret key is shared between sender and recipient for both encryption and decryption.

• Advanced Encryption Standard (AES - FIPS 197):

- Rijndael substitution-permutation network operating on fixed 128-bit blocks.
- Key lengths: 128, 192, or 256 bits (10, 12, or 14 transformation rounds).
- Hardware Acceleration: Modern CPUs integrate AES-NI instruction set executing at > 5 GB/s.

• Block Cipher Modes of Operation:

- ECB (Electronic Codebook): Each 128-bit block encrypted independently with same key; CRITICALLY FLAWED (preserves plaintext patterns; e.g., ECB Penguin).
- CBC (Cipher Block Chaining): Each plaintext block is XORed with previous ciphertext block before encryption; uses Initialization Vector (IV).
- GCM (Galois/Counter Mode): Modern standard; combines high-speed counter mode encryption with authenticated data integrity (AEAD).

Asymmetric Cryptography & Digital Signatures

Public-Key Mathematics: RSA, Elliptic Curves, and Non-Repudiation

• Asymmetric Cipher Principle: Utilizes a mathematically linked Key Pair:

- Public Key: Distributed openly to the entire world; used to encrypt messages or verify signatures.
- Private Key: Kept strictly secret by the owner; used to decrypt messages or generate signatures.

• Mathematical Trapdoor Functions:

- RSA: Based on difficulty of factoring product of two massive prime numbers (2048 to 4096 bits).
- ECC (Elliptic Curve Cryptography): Based on discrete logarithm problem over elliptic curve points (256-bit ECC provides equivalent security to 3072-bit RSA with 1/10th the compute power).

• Digital Signature Mechanics:

1. Sender hashes document: H = SHA-256(Doc).
2. Sender encrypts hash with their PRIVATE KEY to produce the Digital Signature.
3. Recipient decrypts signature using sender's PUBLIC KEY, recalculates hash, and compares. Matching hashes proves Authenticity, Integrity, and Non-Repudiation.

Comprehensive Malware Taxonomy

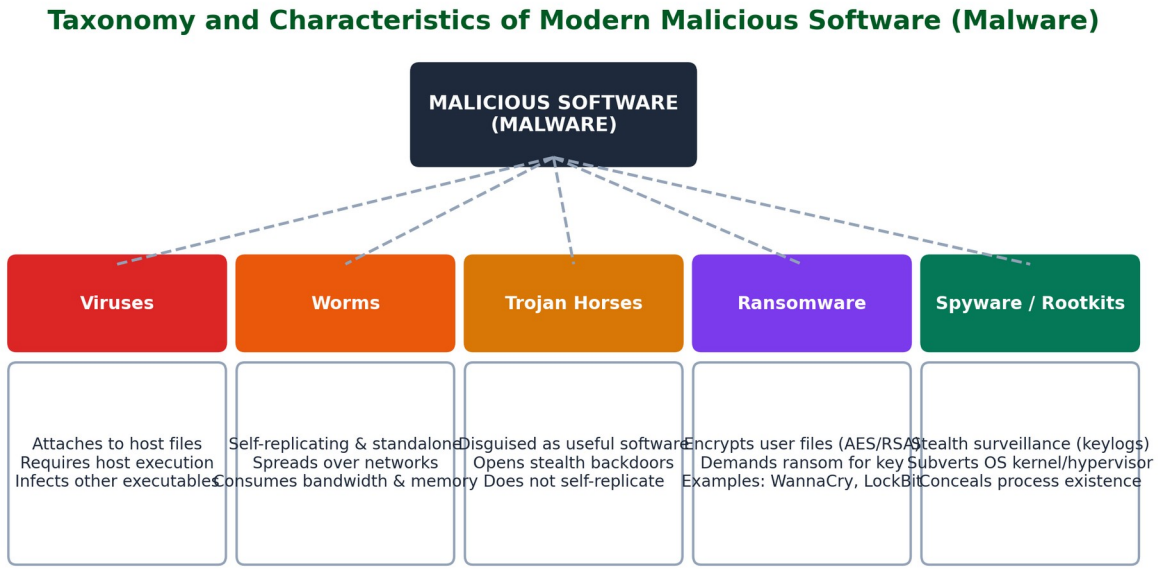


Figure: Taxonomy of malicious software classified by propagation vector, persistence, and payload.

ARCHITECTURAL ANALYSIS & PRINCIPLES

• Autonomous Propagators: Worms (network-scanning automated infectors).

• Host-Dependent Infectors: File viruses, macro viruses, boot sector infectors.

• Deceptive Delivery: Trojan Horses, disguised utilities, fake installers.

• Destructive & Extortion Payloads: Ransomware (crypto-lockers), Wiper malware.

• Espionage & Surveillance: Spyware, Keyloggers, Infostealers, Remote Access Trojans (RATs).

• Deep Stealth & Subversion: Rootkits (Kernel-mode hooks, hypervisor rootkits, firmware bootkits).

Malware Analysis: Viruses vs Worms vs Trojans

Contrasting Infection Vectors and Propagation Dynamics

• Computer Virus:

- Parasitic code that attaches itself to an existing legitimate host executable file (`.exe`, `.docx` macro, boot sector).
- REQUIRES human intervention to propagate (e.g., executing the infected file, inserting an infected USB drive).

• Computer Worm:

- Standalone autonomous program that self-replicates across computer networks without human interaction.
- Scans IP subnets, exploits unpatched network vulnerabilities (e.g., buffer overflows, SMB bugs), and copies itself (e.g., Morris Worm, Code Red, Conficker).

• Trojan Horse:

- Program that appears useful or benign (e.g., 'Free Anti-Virus', 'Crack.exe') but conceals hidden malicious functionality.
- Does NOT self-replicate; relies on deception and social engineering to establish backdoors.

Ransomware: Anatomy of Modern Cyber Extortion

Cryptographic Hijacking, Double Extortion, and The WannaCry Outbreak

• Ransomware Execution Cycle:

1. Initial Access: Phishing email attachment, vulnerable RDP service, or drive-by download.

2. Reconnaissance & Privilege Escalation: Discovers active directory shares, deletes local shadow copies (`vssadmin delete shadows /all /quiet`).

3. Hybrid Encryption Phase: Generates local symmetric AES key, rapidly encrypts user files (`.docx`, `.xlsx`, `.pdf`), and encrypts the AES key using attacker's master RSA-2048 public key.

4. Ransom Demand: Displays ransom note demanding cryptocurrency payment (Bitcoin, Monero) in exchange for private decryption key.

• Double Extortion: Attackers exfiltrate confidential enterprise data to leak sites before encryption, threatening public release if ransom is unpaid.

• WannaCry Outbreak (2017): Combined ransomware with the EternalBlue worm exploit (CVE-2017-0144), paralyzing >200,000 systems in hours.

Spyware, Rootkits, and Botnet Architectures

Stealth Surveillance, Kernel Subversion, and Coordinated Attacks

• Spyware & Keyloggers: Covertly monitors user activity, capturing keystrokes (stealing passwords), capturing screen grabs, and logging web browsing history.

• Rootkits:

- Set of software tools designed to maintain administrator/root access while concealing its presence from the OS.
- User-Mode: Hooks Windows API DLLs to filter directory listings and process trees.
- Kernel-Mode: Modifies kernel system call dispatch tables (SSDT) or kernel memory, rendering detection by standard anti-virus impossible.

• Botnets (Zombie Networks):

- Thousands of compromised microcomputers infected with bots reporting to Command-and-Control (C2) servers.
- Capabilities: Launching massive Distributed Denial of Service (DDoS) flood attacks, sending spam, mining cryptocurrency.

Modern Anti-Malware Defense Methodologies

Beyond Signatures: Heuristics, Behavior & Endpoint Detection and Response

- 1. Signature-Based Detection:
  - Scans files for static sequences of bytes or SHA-256 hashes matching known malware repository.
  - Critical Flaw: Completely blind to Zero-Day exploits and Polymorphic/Metamorphic malware that mutates its binary code on every infection.
- 2. Heuristic Analysis:
  - Decompiles code and searches for suspicious code patterns (e.g., hidden encryption routines, attempts to overwrite MBR).
- 3. Behavioral Monitoring (Anomaly Detection):
  - Continuously inspects active running processes for malicious behavioral anomalies (e.g., process injecting code into `lsass.exe` or rapidly modifying hundreds of files).
- 4. Endpoint Detection and Response (EDR) & Sandboxing:
  - Detonates suspicious executables within isolated micro-virtual machines to analyze network callbacks and filesystem writes before admitting into production.

NIST Incident Response Lifecycle (NIST SP 800-61)

The Four Phases of Enterprise Cyber Incident Handling

• Phase 1 - Preparation: Deploying EDR sensors, hardening endpoints, establishing offline backups, and training incident response team.

• Phase 2 - Detection & Analysis: Monitoring SIEM alerts, determining infection scope, identifying initial attack vector and compromised hosts.

• Phase 3 - Containment, Eradication & Recovery:

- Short-Term Containment: Isolating infected hosts from network (disconnecting Ethernet / blocking VLANs) while preserving volatile RAM forensics.
- Eradication: Terminating malicious processes, removing scheduled task persistence mechanisms, applying missing patches.
- Recovery: Re-imaging systems from known clean gold masters, restoring data from verified immutable backups, verifying security controls.

• Phase 4 - Post-Incident Activity: Conducting 'Lessons Learned' debrief, updating incident response playbooks, and sharing threat intelligence.

Datacenter Climate Control: HVAC & Thermal Containment

ASHRAE Standards, Static Electricity, and Relative Humidity

• The Thermal Threat: Silicon processors generate intense heat (100–300W per CPU socket). Excessive heat causes thermal throttling, hardware degradation, and premature capacitor blowout.

• ASHRAE TC 9.9 Thermal Guidelines for Datacenters:

- Recommended Operating Temperature: 18°C to 27°C (64.4°F to 80.6°F).
- Relative Humidity (RH) Envelope: 40% to 60%.

• Humidity Extremes Threat Model:

- Low Humidity (< 30%): Generates Electrostatic Discharge (ESD); a tiny static spark (> 3,000V) destroys sensitive MOSFET gates on motherboard circuits.
- High Humidity (> 70%): Causes moisture condensation and conductive dust bridging, triggering destructive short circuits.

• Hot-Aisle / Cold-Aisle Containment: Physical separation of cold intake airflow from exhausted hot server air, improving cooling efficiency by >30%.

Fire Suppression in Datacenters: Clean Gaseous Agents

Class C Electrical Fire Suppression Without Liquid Damage

• The Datacenter Fire Challenge: Water sprinklers cause instant electrical shorts and permanently ruin millions of shillings of server hardware.

• Clean Agent Gaseous Systems (NFPA 2001):

- FM-200 (Heptafluoropropane) & Novec 1230 (Fluoroketone): Electrically non-conductive, leaves zero chemical residue, extinguishes fires within 10 seconds by absorbing heat at molecular level.

- Inergen (Nitrogen / Argon / CO₂ blend): Displaces atmospheric oxygen down to 12.5% (starves fire while remaining breathable for humans for short periods).

• Pre-Action Water Sprinkler Systems: Pipes remain dry until two independent smoke detectors trigger, preventing accidental sprinkler burst damage.

Physical Perimeter Security & Defense-in-Depth

Concentric Security Rings Protecting University Datacenters

- Concentric Circles of Protection:
  - Outer Ring: Perimeter fencing, security gates, vehicle barriers, 24/7 security guards.
  - Middle Ring: External building access controlled by proximity RFID keycards and CCTV cameras.
  - Inner Ring (Server Room): Biometric fingerprint/iris locks, mantrap interlock portals (preventing 'tailgating' / piggybacking), anti-passback rules.
  - Core Ring (Equipment Racks): Keyed rack cabinet locks and server chassis intrusion sensors.
- Cable & Device Theft Defenses: Kensington security slots, steel security cabling, and locking port covers.

Cryptographic Key Lifecycle Management

From Generation to Secure Destruction (NIST SP 800-57)

• Security Principle: A cryptographic algorithm is only as secure as the protection of its secret keys.

• The Six Phases of Key Management:

1. Generation: Generated using a certified Hardware True Random Number Generator (TRNG) with high physical entropy.

2. Distribution & Exchange: Exchanged securely using asymmetric trapdoor functions (Diffie-Hellman) or Key Encapsulation Mechanisms (KEM).

3. Storage: Stored inside dedicated Hardware Security Modules (HSMs) or TPM chips; never stored in plaintext on disk.

4. Usage & Access: Strict authorization enforcing separation of duties; keys restricted to specific operations (e.g., signing only, encryption only).

5. Rotation (Crypto-Period): Regular scheduled retirement of old keys to limit the volume of ciphertext encrypted under a single key.

6. Revocation & Destruction: Immediate zeroization when compromised; publishing revocation to CRL/OCSP.

Public Key Infrastructure (PKI) & X.509 Certificates

The Global Web of Trust Validating Digital Identities

• The Impersonation Problem: How does a student know that a public key belonging to `suasms.sua.ac.tz` is authentic and not a hacker's key?

• Certificate Authority (CA): Trusted third-party entity (e.g., DigiCert, Let's Encrypt) that cryptographically binds an organization's public key to their verified identity.

• X.509 Digital Certificate Structure:

- Subject Name (Domain/Entity) & Issuer (CA Name).
- Subject's Public Key.
- Validity Period (Not Before / Not After).
- Digital Signature of the issuing CA.

• Revocation Mechanisms:

- Certificate Revocation List (CRL): CA publishes signed list of revoked certificate serial numbers.
- Online Certificate Status Protocol (OCSP): Real-time query protocol allowing browsers to check revocation status instantly.

Social Engineering: The Human Vulnerability Vector

Exploiting Psychology Rather Than Software Bugs

• Definition: Manipulating people into performing actions or divulging confidential credentials (passwords, banking tokens).

• Attack Taxonomy:

- Phishing: Mass deceptive emails simulating trusted institutions (banks, university portals) directing victims to credential-harvesting web forms.
- Spear-Phishing: Highly targeted, customized attacks directed at specific individuals (e.g., emailing the SUA Bursar regarding a specific supplier invoice).
- Whaling: Spear-phishing targeted directly at high-profile executives (Vice Chancellors, CEOs).
- Vishing (Voice Phishing) & Smishing (SMS Phishing): Phone calls or mobile texts pretending to be telecom providers.
- Watering Hole Attack: Compromising legitimate websites frequently visited by the target group.
- Baiting: Leaving infected USB flash drives in university parking lots or cafeterias labeled 'Exams 2026'.

Living-off-the-Land (LotL) Attacks & Fileless Malware

Subverting Legitimate Operating System Administration Binaries

• Paradigm Shift: Modern sophisticated attackers rarely compile and execute custom `.exe` malware that triggers anti-virus alerts.

• Living-off-the-Land Binaries (LOLBins): Utilizing signed, legitimate administrative OS tools already present on the victim's microcomputer:

- PowerShell & WMI (Windows Management Instrumentation): Executing in-memory encoded scripts.
- `certutil.exe`: Native Windows utility abused to download remote malicious payloads over HTTP.
- `mshta.exe` & `rundll32.exe`: Abused to execute arbitrary malicious DLLs.

• Fileless Malware: Malware residing strictly in volatile system RAM or registry hives; leaves no binary footprint on disk, bypassing traditional file-based signature scanners.

• Defense: Script block logging (PowerShell Event 4104), Constrained Language Mode, and behavioral EDR detection.

Endpoint Detection & Response (EDR) Architecture

Continuous Telemetry, Threat Hunting, and Automated Isolation

- Traditional Anti-Virus vs EDR:
  - Legacy AV: Static gatekeeper; acts only when a file is written to disk matching a known signature.
  - EDR Agent: Flight data recorder continuously streaming low-level operating system events to a central security cloud engine.
- Monitored Telemetry Streams:
  - Process creations and child process spawning trees (e.g., `word.exe` spawning `powershell.exe`).
  - Memory injections and cross-process API hooks (e.g., calls to `VirtualAllocEx` / `WriteProcessMemory`).
  - Network socket connections and domain lookups.
- Automated Containment Capabilities: EDR agent can instantly quarantine a compromised workstation from the university LAN while maintaining an encrypted tunnel for the security team to remediate.

Sandboxing & Dynamic Malware Detonation

Automated Behavioral Analysis in Isolated Micro-Environments

• Sandbox Principle: An isolated, instrumented virtual execution environment where suspicious files are detonated and observed safely.

• Instrumentation Engines: Hooks Windows NT kernel API calls, monitoring:

- Registry key creations (inspecting persistence mechanisms).
- File dropped/encrypted across storage volumes.
- DNS requests and C2 beaconing attempts.

• Malware Sandbox Evasion Tactics & Counter-Measures:

- Sleep Acceleration / Delayed Execution: Malware sleeps for 20 minutes before executing payload; modern sandboxes fast-forward system timers.
- Mouse Movement Checking: Malware waits for user mouse movement; sandboxes simulate realistic human pointer movement.
- Detecting Virtualization Artifacts: Malware inspects MAC addresses and registry for 'VMware' or 'VirtualBox' strings.

Security Information & Event Management (SIEM)

Centralized Log Ingestion, Correlation, and Alert Triaging

• The Log Problem: A university campus generates billions of event logs weekly across firewalls, switches, Linux servers, Windows DCs, and client laptops.

• SIEM Architecture:

1. Log Ingestion: Ingests Syslog, Windows Event Forwarding (WEF), NetFlow, and cloud telemetry.

2. Normalization: Parses disparate log formats into standardized schemas (e.g., Elastic Common Schema).

3. Correlation Engine: Applies threat detection rules across multiple events (e.g., Alert triggers if: 10 failed logins on Windows DC within 60s FOLLOWED BY successful login AND anomalous outbound SSH traffic to unapproved IP).

• Security Orchestration, Automation, and Response (SOAR): Automated playbooks (e.g., automatically blocking malicious IP at the core firewall in milliseconds).

Zero-Trust Architecture (ZTA) in Modern Enterprises

NIST SP 800-207: Never Trust, Always Verify

• Traditional Perimeter Model ('Castle-and-Moat'): Once inside the corporate intranet, everything is trusted; fundamentally flawed because a single compromised laptop allows lateral movement across the entire network.

• Zero-Trust Core Tenets:

1. Assume Breach: Operate as though adversaries already possess an active foothold within the internal network.

2. Never Trust, Always Verify: Every single access request (whether from a dorm room or the Vice Chancellor's desk) must be authenticated, authorized, and encrypted.

3. Least Privilege Access: Grant access strictly on a per-session, just-in-time, just-enough-access basis.

4. Continuous Microsegmentation: Isolate university financial subnets, examination databases, and student Wi-Fi into strictly firewalled micro-segments.

Topic 6: Key Takeaways & Synthesis Matrix

Summary of Data Security & Defense for Course Mastery

• CIA Triad: Confidentiality (Encryption/Access), Integrity (Hashing/Signatures), Availability (UPS/RAID/Backups).

• Environmental Controls: Online Double-Conversion UPS provides zero transfer time; 3-2-1 backup rule guarantees disaster survivability.

• Cryptography: Symmetric (AES) excels at high-throughput bulk data; Asymmetric (RSA/ECC) solves key exchange and digital non-repudiation.

• Malware Taxonomy: Viruses require human file execution; Worms replicate autonomously across networks; Trojans deceive users; Ransomware extorts via hybrid encryption.

• Modern Defenses: Signature scanning must be augmented with behavioral analysis, sandboxing, and EDR agents.

• Incident Response: Follow NIST SP 800-61: Prepare → Detect & Analyze → Contain & Eradicate → Recover → Lessons Learned.

Review Quiz & Knowledge Check

Self-Testing Key Security & Malware Principles

1. What is the fundamental operational difference between a Line-Interactive UPS and an Online Double-Conversion UPS?
2. In the 3-2-1 backup strategy, why is at least one copy required to be stored in an offsite or air-gapped location?
3. Explain why the Electronic Codebook (ECB) mode of AES is considered critically insecure for encrypting structured data.
4. Differentiate between a Computer Virus and a Computer Worm regarding human interaction.
5. What mathematical component allows a digital signature to guarantee Non-Repudiation?

Course Synthesis & Final Assessment Overview

BIT 111 Course Conclusion & Examination Guidelines

• Continuous Assessment Summary:

- Two Assignments (5%) — Completed via 6 Homework assignments.
- Two Theory Tests (15%) — Mid-semester and end-of-semester written theory tests.
- Practical Report (10%) — Laboratory portfolio of terminal, spreadsheet, and security exercises.
- Practical Test (30%) — Timed laboratory hands-on assessment in SMC computer labs.
- University Examination (UE) (40%) — Comprehensive 3-hour theoretical examination covering all 6 topics.
- *Note: Official assessment weights subject to adjustment by Madam Bertha Msuliche Lebalwa (MSc).

• Examination Advice: Focus on mathematical derivations, architectural diagrams, command line syntax, and enterprise agricultural case studies.

• Best wishes to all undergraduate students at Sokoine University of Agriculture!